

Medienformen:	Studienbriefe in schriftlicher und elektronischer Form, Onlinematerial in Lernplattform, Übungen und Projekt über Lernplattform, Online-Konferenzen, Chat und Forum, Präsenzveranstaltung mit Rechner und Beamer.
Literatur:	• Sicherheit in Informationssystemen, (Vorlesungsskript), Daniel Hammer, 2012 • Angewandte Kryptographie, Bruce Schneier, 1996 • Netzsicherheit, Günter Schäfer, 2003 • Cyberwar: Das Internet als Kriegsschauplatz, Sandro Gaycken, 2011 Weitere Literatur wird in der Lehrveranstaltung bekannt gegeben.

Studienbrief 1 Sicherheitsmanagement

1.1 Lernergebnisse

Nach Durcharbeiten dieses Studienbriefs haben Sie einen Einblick in die Angriffe im Internet im Wandel der Zeit, Kenntnisse über das veränderte Sicherheitsumfeld durch zunehmende Vernetzung und über die Entwicklung einer neuen Online-Medienkultur.

Sie können grundlegende Bedrohungsfaktoren der IT-Sicherheit benennen und erklären und Ihnen sind die Mittel und Wirkungsweisen von Angriffen und ihre relevanten Schutzmaßnahmen bekannt. Sie haben außerdem grundlegende Kenntnisse über IT-Sicherheitsanforderungen, kennen die Hauptziele des Sicherheitsmanagements und die unterschiedlichen Kontrollmechanismen.

Des Weiteren erwerben Sie Grundkenntnisse über die Sicherheitspolitik und das Risikomanagement und werden für die Notfallplanung und die betriebliche Kontinuität sensibilisiert.

1.2 Advance Organizer

Ob mittelständischer Betrieb oder Industriekonzern, ob Nichtregierungsorganisationen oder staatliche Organisation, Fragen der Sicherheit spielen in Staat, Wirtschaft und Gesellschaft eine herausragende Rolle. Auf diese neuen Herausforderungen wird in diesem ersten Studienbrief eingegangen.

Branchenanalysten stellen übereinstimmend fest, dass viele Unternehmen, die einen größeren Ausfall hinnehmen müssen, sich auf einem wettbewerbsintensiven Markt nicht lange behaupten werden können. Die IT-Infrastruktur, Ausfallsicherheit, unterbrechungsfreie Geschäftsabläufe und die Onlinesicherung von Geschäftsdaten sind wesentliche Faktoren für einen fortgesetzten geschäftlichen Erfolg.¹

Folgende Fragen interessieren hierbei: Was sind die Aufgaben und Ziele der IT-Sicherheit? Was kann man in der Praxis durch den Einsatz von Sicherheitstechnologien erreichen und was nicht? Was bedeutet Ausfallsicherheit für ein Unternehmen?

1.3 Einführung

Ob mittelständischer Betrieb oder Industriekonzern, ob Nichtregierungsorganisationen oder staatliche Organisation, Fragen der Sicherheit spielen in Staat, Wirtschaft und Gesellschaft eine herausragende Rolle.

Branchenanalysten stellen übereinstimmend fest, dass viele Unternehmen, die einen größeren Ausfall hinnehmen müssen, sich auf einem wettbewerbsintensiven Markt nicht lange behaupten werden können. Die IT-Infrastruktur, Ausfallsicherheit, unterbrechungsfreie Geschäftsabläufe und die Onlinesicherung von Geschäftsdaten sind wesentliche Faktoren für einen fortgesetzten geschäftlichen Erfolg.

Welche Aufgaben und Ziele hat aber IT-Sicherheit? Was kann man in der Praxis durch den Einsatz von Sicherheitstechnologien erreichen und was nicht? Was bedeutet Ausfallsicherheit für ein Unternehmen?

¹ www.rz-muenchen.de/de/solutions/business-continuity-solutions [Stand: 08.09.2016]

Der Begriff der IT-Sicherheit und die damit verbundenen Anforderungen an jeweils konkrete technische Infrastrukturen verändern sich mit der Entwicklung von Computer- und Netzwerktechnologien.

Vor 30 Jahren war die IT-Landschaft vor allem durch Großrechenanlagen in Rechenzentren geprägt. Die massenhafte Nutzung von Computern in privaten Haushalten stand erst noch bevor. Damit verbunden gab es noch nicht die Vielfalt an unterschiedlichen Systemen und Applikationen. Das Aufgabenfeld der Rechentechnik war vor allem in den engeren Rahmen von Forschung und industrieller Entwicklung eingefasst. Dies lässt sich in keiner Weise mit der multimedialen Konsumwelt der heutigen Computerbranche vergleichen.

Heutzutage gibt es allein mehrere Milliarden Internet-Benutzer, deren in Anspruch genommene computergestützte Konsum- und Unterhaltungswelt allein riesige Rechenzentren erfordert. Gleiches betrifft auch Forschung und Wirtschaft, wo inzwischen gigantischer Datenmengen produziert und über Netzwerke ausgetauscht werden.

Das Internet der nächsten Generation ist hochgradig verteilt, heterogen und dynamisch. Man spricht vom Internet der Dinge und Dienste und unter anderem deshalb ist die IT nicht mehr aus unserem Alltag wegzudenken. Mit atemberaubender Geschwindigkeit entsteht global eine neue Informations- und Wissensgesellschaft, die auf der Produktion, Bereitstellung, Sammlung, Auswertung und dem Austausch von Informationen basiert.

Wissen und Information sind zu einer begehrten Ware, einem Machtfaktor geworden. Der Kampf um diesen hat eine neue komplexe Form des neuen Krieges des 21. Jahrhundert geschaffen, den Cyberwar. Das Internet ist nach Ansicht verschiedener Autoren zum Kriegsschauplatz geworden (siehe u.a. Gaycken [2010]). Existiert eine Sicherheitslücke und wird sie ausgenutzt, so kann man auf fremden Rechnern mitlesen, mitschreiben, mithören, sabotieren, manipulieren, löschen, speichern, stören, zerstören etc.

Auch in gesellschaftlichen Sphären, wie den Bereichen der öffentlichen Sicherheit ist der Einzug der Computertechnik deutlich zu spüren. Begriffe wie "Online-Dschihad" gehören inzwischen zum Vokabular von Bundeskriminalamt und dem Bundesamt für Verfassungsschutz². Verfassungsschützer fingen z.B. einen Aufruf zum Cyber-Angriff "auf herausragende Vertreter des Unglaubens" ab.³

Mit dem Internet wächst auch die Netzkriminalität. Allein in Europa entsteht durch Onlinekriminalität jährlich ein Schaden von rund 750 Milliarden Euro.⁴ Diesbezüglich führte der Chef von Interpol im Mai 2012 aus, dass Finanzinstitute in den USA rund 900 Millionen Dollar an Bankräuber verloren hätten, jedoch 12 Milliarden Dollar an Cyberkriminelle.

Die Sicherheit von Computer-Systemen und Daten wird in der digitalen Informationsgesellschaft also immer mehr zu einem zentralen Problem.

Beim elektronischen Geldverkehr, der Verwaltung elektronischer Dokumente und dem Umgang mit personenbezogenen Datenbeständen sind Sicherheit, Schutz vor nicht autorisiertem Zugriff und Missbrauch von vitalem Interesse. Um den Aufgaben des 21. Jahrhunderts gewachsen zu sein, bedarf es deshalb eines ganzheitlichen

² [http://www.verfassungsschutz.de/de/oeffentlichkeitsarbeit/publikationen/pb-islamismus_bzw._„BKA-Präsident: „Internet ist das Tatmittel der Zukunft“](http://www.verfassungsschutz.de/de/oeffentlichkeitsarbeit/publikationen/pb-islamismus_bzw._„BKA-Präsident:_Internet_ist_das_Tatmittel_der_Zukunft“), <http://www.dradio.de/dkultur/sendungen/interview/590511/>

³ 11.02.2012 in der FAZ, Interview mit dem Verfassungsschützer Alexander Eisvogel

⁴ www.itespresso.de/2012/05/10/interpol-beziffert-cybercrime

Sicherheitsmanagements mit vorbereitenden, vorbeugenden, erkennenden und reaktiven Sicherheitsmaßnahmen.

Hier entsteht daher ein großer Markt für Experten, die sowohl die technischen Kenntnisse für einen sicheren IT-Betrieb beherrschen, aber auch mit betriebswirtschaftlichem Denken und Management-Aufgaben vertraut sind.

Dazu gehören Risikoanalysen, die Erstellung von Sicherheitspolicies, Mechanismen zur Zugangskontrolle, Backup und Disaster Recovery, sowie ein organisiertes IT-Incident Management für Unternehmen und deren kritische IT-abhängige Strukturen.

Exkurs 1.1: IT-Incident Management

IT-Incident Management bzw. IT-Störungsmanagement umfasst den gesamten organisatorischen und technischen Prozess der Reaktion auf erkannte oder vermutete Sicherheitsvorfälle bzw. Störungen in IT-Bereichen sowie hierzu vorbereitende Maßnahmen und Prozesse.

Das Spektrum möglicher Vorfälle reicht dabei von technischen Problemen und Schwachstellen bis hin zu konkreten Angriffen auf die IT-Infrastruktur. IT-Incident Management im engeren Sinne muss dabei sowohl organisatorische als auch rechtliche und technische Detailfragen berücksichtigen.

Ziel des Incident-Management-Prozesses ist die schnellstmögliche Wiederherstellung der Service-Leistung.

Unter einer Störung (engl. incident) versteht man nach dem IT Infrastructure Library (ITIL):

Ein Ereignis, das nicht zum standardmäßigen Betrieb eines Services gehört und das tatsächlich oder potenziell eine Unterbrechung dieses Services oder eine Minderung der vereinbarten Qualität verursacht.

ITIL ist eine Sammlung von Best Practices in einer Reihe von Publikationen zur Umsetzung eines IT-Service-Managements (ITSM) und gilt international als De-facto-Standard.

E

IT-Sicherheitsexperten müssen über ein fundiertes Spezialwissen verfügen, um sich auf wechselnde Einsatzgebiete und Aufgaben einzustellen.

Globale Vernetzung, wachsender internationaler Datenaustausch und die Offenheit des Internets erfordern geeignete Sicherheitsmaßnahmen. Durch die aufgezeigten Beispiele wird auch klar, dass die Anforderungen an die IT-Sicherheit ständig steigen und vom Blickpunkt des Betrachters abhängen.

Das Militär und die Geheimdienste sind mehr um Geheimhaltung zum Schutz vor Spionage bemüht, als z.B. die Privatwirtschaft [Meyers and Harris, 2003, Kap.1.8.1]. In der Wirtschaft ist die Kontinuität von Geschäftsprozessen, die Vertraulichkeit von Kundendaten und die Wahrung von Geschäftsgeheimnissen von höchster Priorität.

In der Wissenschaft und Forschung hat die Integrität und die Verfügbarkeit der Daten einen sehr hohen Stellenwert. Ein kontrollierter Wissenstransfer im Forschungsbetrieb ist sehr wichtig.

Für den normalen Computernutzer steht der Schutz seiner persönlicher Daten,

K**Kontrollaufgabe 1.1**

Wieso wird der Bedarf an IT-Sicherheitsexperten weiter enorm steigen?

1.4 Angriffe im Internet im Wandel der Zeit

Im Folgenden werden Ihnen anhand unterschiedlicher Internet-Angriffe das Ausmaß der Auswirkungen in der zeitlichen Abfolge aufgezeigt.

Neue Begriffe wie Malware, Viren, Würmer, Hoaxes und trojanische Pferde werden im letzten Studienbrief erläutert. Hier genügt es nur zu wissen, dass es sich um Schadsoftware handelt.

Ihnen soll bei den folgenden Geschehnissen bewusst werden, wie die Ansprüche an die IT-Sicherheit mit der technischen Entwicklung mitgewachsen sind.

1.4.1 Der Internetwurm

Der sog. „Internetwurm“, welchen am 2. November 1988 um 18:00 Uhr der damalige Student Robert Tappan Morris Jr. startete, gehört zur ersten Schadsoftware, die über das Internet verbreitet wurde. Das damalige Internet befand sich in einem sehr frühen Stadium und beherbergte nur ca. 60.000 Rechner⁵. Der Wurm selbst war seiner Zeit weit voraus, indem er viele Methoden verwendete, die erst Jahre später Eingang in kommerzielle Schadsoftware finden sollten. Als einer der ersten seiner Art ist der Morris-Wurm auch akademisch gut dokumentiert [Rochlis and Eichin, 1989, Spafford, 1989a,b].

Der Wurm sollte nach Einschätzung einer Untersuchungskommission [Eisenberg et al., 1989] eigentlich nichts beschädigen, d.h. keine Daten löschen oder verändern, keine Passwörter oder sonstige Informationen ausspionieren. Er versuchte auch nicht Daten zu zerstören, Superuser-(root-)Rechte zu erlangen oder Accounts bekannter Systemdienste anzugreifen. Er sollte offenbar nur so viele Computer wie möglich infizieren und dabei möglichst unentdeckt bleiben. Doch Programmierfehler hatten schwerwiegende Folgen und führten somit zu seiner Entdeckung.

Befallene Rechner schickten den Wurm nicht nur zu weiteren Maschinen, sie schickten ihn auch zu Computern zurück, auf denen der Wurm bereits lief.

Von diesen Computern aus suchten dann zwei Würmer gleichzeitig nach anderen Rechnern... und dann drei Würmer... und dann vier... Bis am Ende große Teile des Internets kollabierten, weil tausende von Rechnern unter der Last der Wurmprozesse ihren Dienst versagten.

Die Administratoren zogen in Panik die Netzkabel ab, was vor allem den Empfang der E-Mails verhinderte, in denen man in der Zwischenzeit lesen konnte, wie der Wurm funktionierte und was man dagegen unternehmen konnte.

Am 3. November 1988 tagten an der University of California, Berkeley ca. 40 Systemadministratoren und Hacker beim jährlichen Berkeley Unix-Workshop. Hier wurden massive Anstrengungen unternommen, den Wurm zu Disassemblieren⁶

⁵ www.heise.de/ix/artikel/Vertreibung-aus-dem-Paradies-1981722.html

⁶ Disassemblierung = Rückkonvertierung einer binär-codierten Maschinensprache eines ausführbaren Programms in eine lesbare Assemblersprache

und Debuggen, um so dessen Wirkungsweise zu verstehen und die Epidemie beenden zu können.

Am 4. November 1988 konnte von Theodore Ts'o um 12:36 Uhr endlich verkündet werden, dass der UC Berkeley und der parallel dazu im MIT arbeitende „Athena“-Gruppe das vollständige Disassemblieren des Wurms gelungen war.⁷

Schadensbilanz und Konsequenzen

Der Internetwurm bestand aus 99 Code-Zeilen zuzüglich einer Objekt-Datei, die für die Unixe auf VAX- und SUN3-Maschinen kompiliert war (er war vor allem auf diese Art von Unixen fixiert). Er infizierte ca. 6.000 Rechner, die meist durch Überlastung lahmgelegt wurden, welche ungefähr 10 Prozent des damals bestehenden Internets ausmachten.

Der Bundesrechnungshof der USA veranschlagte allein durch den Netzausfall einen Schaden zwischen 100.000 \$ - 10 Mio \$.

Robert Morris wurde festgenommen und zu drei Jahren Haft auf Bewährung, 400 Stunden soziale Dienste, 10.500 US-Dollar sowie der Übernahme der entstandenen Gerichtskosten verurteilt. Seiner akademischen Karriere hat dies aber nicht geschadet. Im Jahr 1993 erhielt er einen Master of Sciences (M.S.), 1999 einen Dokortitel (Ph.D.) in Applied Sciences an der Universität in Harvard und wurde Professor im MIT Computer Science and Artificial Intelligence Laboratory (CSAIL) in der Parallel and Distributed Operating Systems (PDOS) Group.

1.4.2 MS-SQL Slammer - Der erste Highspeed-Wurm

Nur 15 Jahre später bot sich bei einer neuerlichen Wurm-Attacke im Internet ein wesentlich drastischeres Bild. Das Internet selbst war inzwischen enorm gewachsen, der kommerzielle Internetboom hatte um die Jahrtausendwende stattgefunden und eine große Zahl von privaten Internet-Nutzern eroberte das World Wide Web.

Auf der Suche nach potentiellen Gefahrenquellen für seine Kunden war dem Anbieter von Antivirensoftware Kaspersky zwar am 20. Januar 2003 eine verdächtige Software im Netz aufgefallen, er maß dieser aber keine weitere Bedeutung bei.

Am 25. Januar 2003 schlug der als „MS-SQL-Slammer“ bzw. „Saphir-Wurm“⁸ bekannt gewordene Wurm in einer bis daher für eine solche Schadsoftware nicht gekannten Härte und Geschwindigkeit zu. Ausgelöst kurz vor 5:30 Uhr entfaltete dieser neue Wurm eine plötzliche Hyperaktivität und verdoppelte in der 1. Minute seine Population alle 8,5 Sekunden. Bereits nach 3 Minuten erreichte er den Gipfel seiner Aktivität, wobei pro Sekunde nun 55 Mio. IP-Adressen gleichzeitig gescannt wurden. Innerhalb der ersten 10 Minuten infizierte dieser Wurm bereits über 90 % aller potentiell verwundbaren Hosts. Insgesamt infizierte er nach groben Schätzungen ca. 75.000 Hosts. Er avancierte zum bisher schnellsten und ersten Highspeed-Wurm der Computergeschichte^{9,10}.

Die für den MS-SQL-Slammer verwundbaren Systeme sind die Microsoft-Datenbanken „SQL Server 2000“ und alle Microsoft-Systeme, die mit der „MS

⁷ *A Tour of the Worm*, Donn Seeley, Department of Computer Science University of Utah, [http://www.hackerzvoice.net/madchat/vxdevl/avtech/A Tour of the Worm.pdf](http://www.hackerzvoice.net/madchat/vxdevl/avtech/A%20Tour%20of%20the%20Worm.pdf)

⁸ <http://gizmeo.eu/die-10-gefahrlichsten-computerviren-aller-zeiten/>

⁹ Analysis of the Sapphire Worm - A joint effort of CAIDA, ICSL, Silicon Defense, UC Berkeley EECS and UC San Diego CSE, www.caida.org/research/security/sapphire/

¹⁰ <http://news.sciencemag.org/2003/02/fastest-worm-ever>

Desktop Engine (MSDE) 2000“ ausgestattet waren. Letzterer Umstand ist interessant, da die Firma Microsoft, vom Hacker David Litchfield über die Schwachstelle informiert, einen Sicherheitsupdate für die entsprechende Datenbanksoftware bereitstellte¹¹. Dass aber auch eine Vielzahl weiterer Applikationen wie „MS-Project“, „MS Visual Studio“, „MS Access“, etc. betroffen war blieb zunächst verborgen und führte in Konsequenz auch dazu, dass entsprechende Computer nicht mit dem schützenden Sicherheitsupdate versorgt wurden.

Die Geschichte des MS-SQL-Slammer Wurms ist damit auch ein Beispiel dafür, wie schwierig es ist, Sicherheit in proprietären, sog. Close Source, Systemen durchzusetzen, da der Nutzer weder Einblick in den Quellcode, noch die wirkliche Funktionsweise und Zusammensetzung der Software hat und allein dem auf Gewinnmaximierung orientierten jeweiligen Hersteller vertrauen muss.

E

Exkurs 1.2: Close Source

Bei Closed-Source-Software ist der Quellcode nicht öffentlich bekannt. Die Software kann somit von der Öffentlichkeit weder einer Qualitätskontrolle noch Änderungen bzw. Anpassungen an individuelle Bedürfnisse unterzogen werden und bleibt somit auch in ihrem Funktionsumfang dem Nutzer verschlossen. Closed-Source-Software ist das Gegenteil von Open-Source-Software.

Es wird eine unendliche Kommunikationsschleife unter SQL Servern erzeugt und ein extrem hoher Netzverkehr durch Angriffspakete findet statt.

Weiterhin bemerkenswert am MS-SQL-Slammer ist auch der Umstand, dass die gesamte Schadsoftware in ein einziges UDP-Netzwerkpaket (UDP = verbindungsloses Protokoll) passt und nur 376 Byte groß ist (UDPs werden im Studienbrief 4 ausführlicher erklärt). Somit reicht nur ein einziges Paket aus, um einen verwundbaren Host zu infizieren. Dieser Umstand und eine neuartige Technik zum Finden neuer Opfer von einem infizierten System heraus, trugen zur enormen Geschwindigkeit des MS-SQL-Slammer bei.

Schadensbilanz und Konsequenzen

Innerhalb weniger Stunden setzte der Wurm MS-SQL-Slammer am Samstag, den 25. Januar 2003 Teile des Internets praktisch außer Gefecht¹².

Südkorea wurde besonders hart getroffen, da es vom Internet faktisch abgetrennt wurde und das Handelsvolumen der dortigen Börse auf den tiefsten Stand seit 13 Monaten fiel¹³. In Amerika fielen 13.000 Geldautomaten der Bank of America aus und bei den Continental Airlines kam es zu Flugverzögerungen. US 911-Systeme und mehrere Telefonanbieter fielen aus, die Steuerungssysteme zweier Atomkraftwerke in den USA waren betroffen und auch Atomkraftwerke in Kanada wurden gestört.¹⁴

Die Schadensbilanz beträgt ca. 1,25 Mrd \$ allein durch Netzausfall. Zum Glück verhinderte das Wochenende noch größere Schäden. Der Verursacher konnte bis heute nicht ermittelt werden.

¹¹ *The Inside Story of SQL Slammer*, David Litchfield, <http://threatpost.com/inside-story-sql-slammer-102010/74589>

¹² www.tecchannel.de/sicherheit/spam/402050/ms_sql_slammer_ein_wurm_und_die_konsequenzen/

¹³ Slammer, <http://malware.wikia.com/wiki/Slammer>

¹⁴ 'Slammer' attacks may become way of life for Net, www.spiegel.de/netzwelt/tech/sql-slammer-das-versagen-der-sicherheitsexperten-a-232534.html